배터리 물리 이상탐지 설계 정리

보안 해커톤 — ESS 전 구간 보안 모니터링 / 물리 이상탐지 파트 · 2026-10-31

핵심 아이디어 — 배터리는 물리 법칙을 따른다. 보고된 값들이 서로 물리적으로 모순되면 위조나 고장을 의심한다. 탐지 범위는 배터리 근접 구간(CAN / BMS ↔ ESS EMS)으로 한정한다.

1. 검증에 쓰는 물리 관계

관측 값: 셀 전압, 팩 전압, 전류, 온도, SOC

관계	내용	깨지면 의심할 것
전압 합	직렬 셀 전압의 합 ≈ 팩 전압	특정 셀 값 위조
SOC 적분	SOC 변화량 ≈ 흐른 전류의 누적($\int I\,dt$) ÷ 용량	SOC 위조
충전 방향	충전 전류가 흐르면 전압과 SOC가 올라야 함	값 고정, 리플레이
발열	큰 전류가 흐르면 온도가 올라야 함 (I^2R)	온도 은폐
변화율 한계	온도나 SOC가 1초 만에 크게 튈 수 없음	조작된 값 주입

2. 시나리오 예시

S1. 과충전 은폐 (SOC 위조)

공격 BMS → EMS 구간(Modbus)에서 실제 SOC 98%를 70%로 보고되게 조작한다. EMS는 여유가 있다고 판단해 계속 충전한다.

탐지 전류 적분으로 계산한 SOC와 보고된 SOC가 어긋난다. CAN 구간에서는 98%로 관측되므로 홉 간 불일치도 함께 잡힌다.

S2. 온도 은폐 (열폭주 전조 숨김)

공격 온도를 25°C 고정값으로 보고한다.

탐지 고전류가 계속 흐르는데 온도 변화가 0이다. 발열 관계 위반이며, 값의 분산이 0인 것 자체도 이상 신호다.

S3. 리플레이

공격 과거의 정상 데이터를 녹화해 두었다가 재전송한다.

탐지 EMS가 충전 명령을 내렸는데 전류·전압 응답이 명령과 맞지 않는다. 명령–응답 불일치로 탐지한다.

S4. 셀 전압 위조

공격 셀 하나의 전압을 정상값으로 덮어써서 불량 셀을 숨긴다.

탐지 셀 전압 합이 팩 전압과 어긋난다.

3. 시스템 구성

실제 하드웨어 없이 전부 소프트웨어로 구성하며, Docker 네트워크 하나에 올릴 수 있다.

```
[배터리 시뮬레이터] ─CAN(vcan)→ [BMS 에뮬레이터] ─Modbus TCP→ [ESS EMS 에뮬레이터]
                          |                          ↑ (공격 지점: Modbus 프록시)
                    [수집기: CAN 스니핑 + Modbus 패킷 캡처]
                                    ↓
                          [물리 검증 엔진] → [SIEM]
```

구성요소	역할	구현할 것
배터리 시뮬레이터	진짜 배터리 대신 물리 법칙을 따르는 값 생성	단순 모델(OCV 곡선 + 내부저항 + 열모델)로 충방전을 계산해 CAN으로 송출
BMS 에뮬레이터	CAN 값을 받아 Modbus 레지스터로 노출	python-can 수신 + pymodbus 서버 + 레지스터 맵 정의
ESS EMS 에뮬레이터	주기적으로 상태를 읽고 충방전 명령	pymodbus 클라이언트 + 단순 제어 로직 (예: SOC 90% 이상이면 충전 중지)
공격 도구	시나리오별 값 조작	중간에 Modbus 프록시를 끼워 응답 레지스터 변조 (ARP 스푸핑보다 구현이 쉬움)
수집기	두 구간의 원본 값 확보	CAN 프레임과 Modbus 패킷을 파싱해 통일된 이벤트 형식으로 정규화
물리 검증 엔진	**이 파트의 핵심**	시간 윈도우마다 1장의 관계식을 계산 → 허용오차 초과 시 경보·점수를 SIEM으로 전송

물리 검증 엔진 동작 흐름

1. 수집기에서 정규화된 값을 시계열로 받는다
2. 몇 초 단위 윈도우로 묶는다
3. 관계식마다 잔차를 계산한다. 예: |보고된 SOC 변화 − 적분 SOC 변화|
4. 임계값과 비교하고, 연속으로 몇 번 초과하면 경보를 낸다 (오탐 방지)
5. 어떤 관계가 깨졌는지와 위험도를 SIEM으로 전송한다

4. 범위 선택지

S1~S4는 시뮬레이터와 검증 엔진을 공유하고 **관계식 룰만 하나씩 추가되는 구조**이므로, 1~2개로 시작해 늘려 가면 된다.

선택지	특징
S1만 추천	가장 단순. 화재 스토리와 홉 간 검증까지 한 번에 보여줄 수 있음
S1 + S2	"화재 전조 은폐" 스토리가 더 강해짐
S1 + S3	리플레이까지 잡아 보안 관점이 더 강조됨

다음에 정할 것

- 시나리오 범위 선택 (위 표)
- 선택한 시나리오 기준의 레지스터 맵, 시뮬레이터 모델, 검증 룰 상세 설계